

Security+ 1.2 · Zero Trust

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.2 — Zero Trust (10:04)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Zero Trust is a security architecture based on 'never trust, always verify.' Every access request is authenticated and authorized based on identity, device health, and context, regardless of network location. Micro-segmentation isolates workloads, and Continuous Access Evaluation (CAE) revokes sessions in real time upon critical events.

High-Yield Core Concepts Tested on Exam

- Never trust, always verify — even for internal network traffic
- Three pillars: Identity (IAM/MFA), Device (MDM/EDR), Network (micro-segmentation)
- CAE revokes sessions in real time, not waiting for token expiration
- Zero Trust is an architecture, not a product
- Micro-segmentation limits lateral movement

Exam Tips & Classic Scenarios

- Scenario with 'even inside the network' = Zero Trust
- 'Continuous access evaluation' or 'revokes in real time' = CAE
- Zero Trust is not a single product; it is a strategic approach
- If the question mentions 'never trust, always verify', answer Zero Trust

Typical Exam Scenario: A company authenticates every access request even from inside the corporate network and revokes sessions immediately upon detecting risk. This is an example of Zero Trust with Continuous Access Evaluation (CAE).

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.2 — Zero Trust)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **SP:** Service Provider: Web application or cloud SaaS service (e.g. Salesforce, M365) that relies on the Identity Provider to authenticate users and grant access.
- **ZTNA:** Zero Trust Network Access: Architectural model replacing legacy VPNs by granting least-privilege, identity-verified, contextual access to individual applications rather than entire subnets.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. The classic 'castle and moat' perimeter security model (where everything inside the internal network is trusted) has been superseded by the Zero Trust model. What is the motto and fundamental operational principle of Zero Trust?

- A)** 'Never trust, always verify'
- B)** 'Trust the internal perimeter and inspect only the internet'
- C)** 'Trust all computers that have antivirus'
- D)** 'Block all network traffic permanently'

2. In a Zero Trust architecture based on the NIST SP 800-207 standard, which component evaluates user context (device health, location, MFA) and decides whether to grant or deny the session?

- A) Policy Decision Point (PDP) / Policy Engine**
- B) Policy Enforcement Point (PEP) only**
- C) Unmanaged Layer 2 switch**
- D) Magnetic tape backup server**

3. Which network technique is essential in Zero Trust to prevent an attacker who has infected a workstation from moving laterally to the financial server on the same VLAN?

- A) Network microsegmentation**
- B) Increasing switch bandwidth**
- C) Using shielded twisted pair cables**
- D) Disabling logs on routers**

4. An employee on a business trip accesses the corporate portal with their company laptop. Minutes later, a login attempt with the same user appears from a country 10,000 km away. The Zero Trust system immediately blocks the second session based on:

- A) Contextual risk analysis and 'impossible travel'**
- B) Excessive RAM usage in the browser**
- C) Ping command response time**
- D) Number of characters in the typed password**

5. In the Zero Trust ecosystem, what does the concept of Continuous Access Evaluation (CAE) mean?

- A) The user's permission and access token are re-evaluated in real time at each critical event, and the session can be revoked instantly**
- B) The user must manually re-enter their password every 60 seconds**
- C) Network traffic is restarted every hour to clear the cache**
- D) The computer is automatically shut down if it becomes idle**

6. What are the 3 primary pillars evaluated by a Zero Trust architecture to authorize access to a critical resource?

- A)** Verified identity, device health posture, and request context/environment
- B)** Processor speed, case color, and router brand
- C)** Work hours, monitor size, and mobile carrier
- D)** Exclusive Linux operating system, fiber cables, and optical switches

7. How does the principle of Least Privilege manifest in access implementation in a Zero Trust network?

- A)** The user receives 'Just-In-Time' (JIT) and 'Just-Enough-Access' (JEA) strictly limited to the resource needed for the duration of the task
- B)** All employees receive administrator privileges to streamline support
- C)** No one in the company can access any system under any circumstances
- D)** Only the finance department has access to computers

8. Which modern remote connectivity solution replaces traditional VPN in the Zero Trust model, allowing direct and secure access to specific applications without exposing the entire corporate network?

- A)** ZTNA (Zero Trust Network Access)
- B)** Telnet with simple authentication
- C)** RDP with default port open on the router
- D)** VNC without encryption

9. A company implements Zero Trust and requires that personal computers (BYOD) cannot access confidential data unless they have an updated operating system, encrypted disk, and active antivirus. This check is known as:

- A)** Device Posture Check / Health Attestation
- B)** Reverse asymmetric key authentication
- C)** Static packet filter on the router
- D)** Batch TCP header inspection

10. Why can Zero Trust NOT be acquired as an off-the-shelf 'product' or a single appliance box?

- A)** Because Zero Trust is a comprehensive architectural and philosophical model that involves integrating IAM, endpoints, networks, data, and applications
- B)** Because the technology is prohibited by federal laws
- C)** Because it only works on quantum computers
- D)** Because it is restricted to aerospace defense companies

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — 'Never trust, always verify'.

✓ **Why it's correct:** The motto 'Never trust, always verify' encapsulates the fundamental operational principle of Zero Trust, as defined by NIST SP 800-207 and adopted by CompTIA Security+ SY0-701. Instead of assuming that any entity inside the network perimeter is trusted (the 'castle and moat' model), Zero Trust requires that every access request be explicitly authenticated and authorized, regardless of its origin (internal or external). This implies continuous verification of identity, device context, location, endpoint health, and other attributes, applying the principle of least privilege and assuming the network is always compromised. Zero Trust architecture relies on dynamic policies that grant access only for the necessary time and with minimal permissions, constantly reassessing session conditions.

✗ **Why the others are wrong:**

- *'Trust the internal perimeter and inspect only the internet'*: This alternative describes the traditional perimeter security model, also known as 'castle and moat', which is exactly the paradigm that Zero Trust replaces. In this model, everything inside the internal network is assumed trusted, and protection focuses on the edge (firewalls, IDS/IPS). Zero Trust rejects this premise because insider attacks, lateral movement, and advanced persistent threats (APTs) can originate within the perimeter. Therefore, blindly trusting the interior of the network is a critical vulnerability that Zero Trust eliminates with continuous verification.
- *'Trust all computers that have antivirus'*: This option reflects a naive trust approach based solely on the presence of antivirus software. In Zero Trust, trust is neither binary nor based on a single control. Device health is one of many contextual signals evaluated, but it is not sufficient to grant unrestricted access. An endpoint can have up-to-date antivirus and still be compromised (e.g., by fileless malware or zero-day exploitation). The principle 'never trust, always verify' requires continuous validation of multiple factors, including identity, security posture, location, and behavior, not just the existence of antivirus.
- *'Block all network traffic permanently'*: This alternative describes a total denial of service, which is the opposite of Zero Trust's goal. Zero Trust does not block all traffic; it allows access based on granular policies and verified context. Blocking everything permanently would render the network inoperable and is not a viable security strategy. The principle is 'never trust, always verify', meaning access is granted after verification, not absolutely denied. The total blocking approach violates availability and usability, pillars of the CIA triad, and does not represent the Zero Trust model.

2) A — Policy Decision Point (PDP) / Policy Engine.

✓ **Why it's correct:** In the NIST SP 800-207 standard, the Policy Decision Point (PDP) is the central component that evaluates user context (such as device health, location, multi-factor authentication, time, behavior) and decides whether to grant, deny, or revoke access to a resource. The PDP consists of the Policy Engine (PE), which makes the decision based on defined policies, and the Policy Administrator (PA), which establishes communication with the Policy Enforcement Point (PEP) to execute the decision. The PDP is responsible for applying the principle 'never trust, always verify', continuously analyzing context signals and issuing tokens or instructions to the PEP to allow or block the session. It is the key piece for dynamic policy enforcement in a Zero Trust architecture.

✗ **Why the others are wrong:**

- *Policy Enforcement Point (PEP) only*: The Policy Enforcement Point (PEP) is the component that executes the decision made by the PDP, acting as a gateway or proxy that allows or blocks traffic based on received instructions. It does not evaluate context or make decisions; its function is only

to enforce policy. Therefore, stating that the PEP 'only' decides is incorrect, as it depends on the PDP for decision logic. In NIST SP 800-207, the PEP is the enforcement point, not the decision point.

- *Unmanaged Layer 2 switch*: An unmanaged Layer 2 switch is a network device that forwards Ethernet frames based on MAC addresses, with no capability to evaluate user context, device health, or access policies. It lacks authentication, authorization, or risk analysis features. In a Zero Trust architecture, unmanaged switches have no role as a PDP; they may even be used as part of the infrastructure, but they do not make access decisions. This option is completely inapplicable to the policy evaluation context.
- *Magnetic tape backup server*: A magnetic tape backup server is a data storage system for disaster recovery, with no function for context evaluation or real-time access decisions. It does not interact with user authentication, session policies, or risk analysis. In Zero Trust, backups are important for resilience, but they are not components of the control plane that decides on access grants. This option is an obvious distractor and does not relate to the PDP or PEP.

3) A — Network microsegmentation.

✓ **Why it's correct:** Network microsegmentation is the essential Zero Trust technique to prevent lateral movement. It involves dividing the network into highly granular logical segments, applying specific security policies per workload, application, or even per process. Unlike traditional VLAN-based segmentation, microsegmentation allows the creation of isolated trust zones, where traffic between segments is inspected and authorized based on identity and context, not just IP addresses. Thus, if a workstation is compromised, the attacker cannot move laterally to the financial server, because traffic between them is blocked by default unless there is an explicit policy allowing it. This implements the principle of least privilege at the network level and is a pillar of Zero Trust.

✗ **Why the others are wrong:**

- *Increasing switch bandwidth*: Increasing switch bandwidth improves network performance, allowing higher data throughput, but provides no security control or isolation. An attacker already inside the network can move laterally regardless of available bandwidth. Bandwidth does not prevent malware propagation or unauthorized access to servers; it only facilitates data transfer. Therefore, it is not a security measure and does not meet the requirement to prevent lateral movement.
- *Using shielded twisted pair cables*: Shielded twisted pair (STP) cables are designed to reduce electromagnetic interference and crosstalk, improving signal integrity in noisy environments. They do not provide logical security against cyber attacks, such as lateral movement. An attacker who gains access to a workstation can move across the network regardless of the physical cabling type. Shielding protects against physical interception and interference, but not against insider threats or endpoint compromise. It is neither a microsegmentation nor a Zero Trust technique.
- *Disabling logs on routers*: Disabling logs on routers is a practice that reduces audit and monitoring capability, the opposite of security best practices. Logs are essential for intrusion detection, forensic analysis, and incident response. By disabling them, the organization loses visibility into malicious activities, including lateral movement. Moreover, it does not prevent an attacker from moving across the network; it only hinders detection. In Zero Trust, continuous visibility is fundamental, and disabling logs violates monitoring and response principles. Therefore, it is an incorrect and harmful alternative.

4) A — Contextual risk analysis and 'impossible travel'.

✓ **Why it's correct:** Contextual risk analysis and the concept of 'impossible travel' are Zero Trust mechanisms that evaluate geographic location and time between accesses to detect anomalies. In the described scenario, the employee accesses the portal from one location, and minutes later, a

login attempt appears from a country 10,000 km away. Since it is physically impossible to cover that distance in the time interval, the system classifies it as high-risk activity, possibly indicating compromised credentials. Based on this contextual analysis, the Policy Decision Point (PDP) immediately blocks the second session, applying the 'never trust, always verify' principle. This demonstrates Zero Trust's ability to make dynamic decisions based on context signals such as location, time, and behavior, rather than relying solely on initial authentication.

✗ Why the others are wrong:

- *Excessive RAM usage in the browser:* Browser RAM consumption is an endpoint performance factor, not a contextual security signal for access decisions. While device health may include resource metrics, excessive RAM does not necessarily indicate a threat to identity or session. Blocking the second session based on this criterion would be arbitrary and not aligned with Zero Trust principles, which assess authentication and authorization risks such as location, device, and user behavior. Therefore, it is an irrelevant alternative to the impossible travel scenario.
- *Ping command response time:* Ping response time is a network latency measure used to diagnose connectivity and performance. It is not a contextual security indicator for authentication or authorization. An attacker could be geographically close and still have high latency, or distant and have low latency due to efficient routing. Zero Trust does not use ping as a criterion to block sessions; it relies on signals such as location, IP reputation, device health, and behavioral analysis. Therefore, this option does not apply to the scenario.
- *Number of characters in the typed password:* Password length is an authentication complexity metric, but not a dynamic contextual signal for real-time decisions. Zero Trust may require strong password policies, but blocking the second session would not occur because the password has more or fewer characters. The decision is based on factors such as impossible location, untrusted device, or anomalous behavior. Additionally, password length does not indicate compromise; an attacker could use the correct password. Therefore, it is an alternative unrelated to the impossible travel scenario.

5) A — The user's permission and access token are re-evaluated in real time at each critical event, and the session can be revoked instantly.

✓ **Why it's correct:** Continuous Access Evaluation (CAE) is a Zero Trust mechanism that continuously re-evaluates the authorization of a user or device during an active session, rather than relying solely on initial authentication. At each critical event—such as a change in location, alteration in the device's security posture, revocation of privileges, or detection of an anomaly—the access token is revalidated in real time. If the context becomes insecure, the session can be revoked instantly, even if the token has not yet expired. This implements the principle 'never trust, always verify' continuously, reducing the window of exposure to threats. CAE is supported by protocols such as OAuth 2.0 and OpenID Connect, allowing identity providers and applications to exchange signals in real time.

✗ Why the others are wrong:

- *The user must manually re-enter their password every 60 seconds:* This alternative describes a policy of frequent manual reauthentication, which is impractical and does not represent the concept of Continuous Access Evaluation. CAE does not require the user to re-enter the password every minute; instead, the evaluation is automatic and based on context signals, without user intervention. Frequent manual reauthentication would harm productivity and is not a recommended practice. The goal of CAE is to balance security and usability, re-evaluating access transparently and continuously, not through constant password prompts.
- *Network traffic is restarted every hour to clear the cache:* Periodically restarting network traffic to clear cache is a performance maintenance practice, not a security mechanism. It has no relation to

Continuous Access Evaluation, which focuses on re-evaluating authorization based on context. Restarting traffic does not revoke tokens or re-evaluate policies; it may even cause unwanted interruptions. CAE operates at the identity and access layer, not the transport layer. Therefore, this alternative is incorrect and does not describe the concept.

- *The computer is automatically shut down if it becomes idle:* Automatically shutting down an idle computer is a power-saving or physical security policy, but it does not relate to Continuous Access Evaluation. CAE deals with re-evaluating resource access sessions, not the power state of the endpoint. A computer can be idle and still maintain active sessions that need to be re-evaluated. Furthermore, automatic shutdown does not revoke tokens or enforce Zero Trust policies. Therefore, this option is a distractor that does not represent the concept of CAE.

6) A — Verified identity, device health posture, and request context/environment.

✓ **Why it is correct:** Zero Trust architecture is based on the principle of 'never trust, always verify'. To authorize access to a critical resource, it continuously evaluates three primary pillars: (1) Verified identity – assurance that the user or service is who they claim to be, typically through multifactor authentication (MFA) and credential verification; (2) Device health posture – assessment of the security state of the device requesting access, including up-to-date patches, active antivirus, encrypted disk, among others; and (3) Request context/environment – factors such as geographic location, time, source network, user behavior, and operation risk level. These three elements are combined to make a dynamic authorization decision, aligned with the Zero Trust model in CompTIA Security+ SY0-701.

✗ **Why the others are wrong:**

- *Processor speed, case color, and router brand:* These are physical or hardware attributes unrelated to the security pillars evaluated by Zero Trust. Processor speed may influence performance but is not an authorization factor; case color is irrelevant to security; and router brand does not determine trust. Zero Trust focuses on identity, device health, and context, not aesthetic or brand characteristics.
- *Work hours, monitor size, and mobile carrier:* Work hours can be a component of context but alone is not a primary pillar; monitor size is a physical characteristic with no security impact; and mobile carrier may be part of network context but is not one of the three main pillars. The correct answer requires the triad of identity, device posture, and context, not a random combination of peripheral factors.
- *Exclusive Linux operating system, fiber cables, and optical switches:* These are infrastructure and platform elements, not Zero Trust decision pillars. Requiring a specific operating system (Linux) is a restrictive policy but not an authorization pillar; fiber cables and optical switches refer to the physical layer, which is not dynamically evaluated by the Zero Trust model. The focus is on identity, device health, and request context, not specific network technologies.

7) A — The user receives 'Just-In-Time' (JIT) and 'Just-Enough-Access' (JEA) strictly limited to the resource needed for the duration of the task.

✓ **Why it is correct:** In the Zero Trust model, the principle of Least Privilege is implemented through Just-In-Time (JIT) and Just-Enough-Access (JEA). This means the user receives permissions only when necessary (JIT) and limited exactly to the resource required to perform a specific task (JEA), for the strictly necessary time. After task completion, privileges are automatically revoked. This approach reduces the attack surface and the risk of lateral movement, aligning with the motto 'never trust, always verify' and the concept of dynamic least privilege, as per CompTIA Security+ SY0-701.

✗ **Why the others are wrong:**

- *All employees receive administrator privileges to streamline support:* Granting administrator

privileges to all employees directly violates the principle of least privilege. This exponentially increases the risk of misuse, account compromise, and lateral movement. Zero Trust requires privileges to be minimal and granted on demand, not broad and permanent. This practice is considered a serious security flaw.

- *No one in the company can access any system under any circumstances*: This statement describes a total denial of access, which is not the goal of least privilege. The principle aims to grant necessary access to perform job functions, but in a restricted and controlled manner. Denying all access would prevent company operations and is not a valid Zero Trust implementation, which seeks to enable business securely, not paralyze it.
- *Only the finance department has access to computers*: This alternative confuses least privilege with extreme departmental segregation. Least privilege applies to all users and resources, not just one department. Furthermore, restricting computer access only to finance makes no operational sense and does not address dynamic privilege granting based on need. Zero Trust requires continuous evaluation of context and identity for all access.

8) A — ZTNA (Zero Trust Network Access).

✓ **Why it is correct:** ZTNA (Zero Trust Network Access) is the modern solution that replaces traditional VPN in the Zero Trust model. It provides secure, direct access to specific applications without exposing the entire corporate network. Instead of granting network-wide access, ZTNA establishes an encrypted point-to-point tunnel between the user and the application after verifying identity, device posture, and context. This implements the 'never trust, always verify' principle and reduces the attack surface, making it the correct answer according to CompTIA Security+ SY0-701.

✗ Why the others are wrong:

- *Telnet with simple authentication*: Telnet is a legacy protocol that transmits data, including credentials, in plaintext without encryption. Simple authentication offers no protection against interception or brute-force attacks. Moreover, Telnet is not a modern remote connectivity solution and does not align with Zero Trust requirements, which demand strong encryption and continuous verification. Therefore, it is completely inadequate.
- *RDP with default port open on the router*: Exposing RDP (Remote Desktop Protocol) on the default port (3389) directly to the internet is a high-risk practice, as it attracts brute-force attacks, vulnerability exploitation, and ransomware. Even with RDP, there is no device posture or context verification, and access is to the internal network, not to specific applications. Zero Trust recommends avoiding direct exposure and using solutions like ZTNA.
- *VNC without encryption*: VNC (Virtual Network Computing) without encryption transmits the session and credentials in plaintext, allowing interception and unauthorized access. Additionally, it does not offer robust identity verification, device posture, or context. It is an obsolete and insecure technology for remote access, completely incompatible with Zero Trust principles and security best practices.

9) A — Device Posture Check / Health Attestation.

✓ **Why it is correct:** Device Posture Check / Health Attestation is the process of evaluating a device's security state before granting access to confidential resources. In a Zero Trust context, this includes checking if the OS is updated, disk is encrypted, antivirus is active and updated, among other requirements. This assessment is continuous and part of the 'device health posture' pillar, ensuring only compliant devices can access sensitive data, as per CompTIA Security+ SY0-701.

✗ Why the others are wrong:

- *Reverse asymmetric key authentication*: This term does not exist in information security literature. Asymmetric key authentication involves a public-private key pair, but 'reverse' is not a recognized concept. Additionally, key-based authentication verifies user identity, not device security posture

(updates, encryption, antivirus). Therefore, it does not apply to the described scenario.

- *Static packet filter on the router*: Static packet filtering is a firewall technique that allows or blocks traffic based on IP addresses, ports, and protocols, without inspecting content or device state. It does not check if the OS is updated, disk is encrypted, or antivirus is active. This approach is insufficient for Zero Trust, which requires dynamic evaluation of device posture.
- *Batch TCP header inspection*: Batch TCP header inspection refers to analyzing TCP header fields, such as ports and flags, for filtering or routing purposes. It does not assess device health, nor does it check updates, disk encryption, or antivirus. It is a low-level network technique that does not meet the requirements for device posture checking in the Zero Trust model.

10) A — Because Zero Trust is a comprehensive architectural and philosophical model that involves integrating IAM, endpoints, networks, data, and applications.

✅ **Why it is correct:** Zero Trust is not a single product or appliance, but a comprehensive architectural and philosophical model that requires integrating multiple components: identity and access management (IAM), endpoint security, network microsegmentation, data protection, application security, visibility, and analytics. Successful implementation requires cultural change, consistent policies, and interoperable technologies. Therefore, it cannot be bought as an off-the-shelf 'box' but must be built through a holistic strategy, per CompTIA Security+ SY0-701.

❌ **Why the others are wrong:**

- *Because the technology is prohibited by federal laws*: There is no federal law prohibiting Zero Trust technology. On the contrary, governments and regulators often encourage its adoption to improve cybersecurity. The statement is factually incorrect and based on no real legal restriction. The reason Zero Trust is not a single product is architectural, not legal.
- *Because it only works on quantum computers*: Zero Trust does not depend on quantum computing. It is implemented with current technologies such as multi-factor authentication, microsegmentation, behavioral analytics, and classical encryption. Quantum computers are a future concern for cryptography but are not a prerequisite for Zero Trust. This option confuses concepts and does not reflect information security reality.
- *Because it is restricted to aerospace defense companies*: Zero Trust is applicable to organizations of all sizes and sectors, including healthcare, finance, retail, and government. There is no restriction to aerospace defense. Adoption is recommended by frameworks such as NIST SP 800-207 and widely implemented across sectors. The statement is false and does not explain why Zero Trust is not an off-the-shelf product.